

GUÍA METODOLÓGICA Y NARRATIVA TÉCNICA DEL RECORRIDO DE ATAQUE (KILL CHAIN)

*Documentación Práctica Basada en Herramientas de Acceso Gratuito y de
Código Abierto (Open Source)*

Asignatura: Seguridad en Sistemas y Redes (SSR)
Anexo de Pruebas de Concepto (PoC) por Capas OSI

Fecha: Junio de 2026
Licencia de Herramientas: Open Source / Comunidad

1. Introducción Metodológica

El presente anexo técnico detalla los procedimientos operativos y las pruebas de concepto (PoC) requeridas para validar la cadena de ataque dirigida (Kill Chain) diseñada sobre el modelo OSI. Con el fin de cumplir con las directrices académicas y de reproducibilidad de la asignatura Seguridad en Sistemas y Redes (SSR), se han seleccionado exclusivamente herramientas de seguridad de acceso gratuito, pertenecientes a la comunidad o de código abierto (Open Source).

Este documento descarta la inclusión de guías genéricas o tutoriales básicos de instalación, enfocándose de manera estricta en la aplicación táctica del comando o la configuración específica que permite el avance interconectado del atacante desde la capa física hasta la capa de aplicación.

2. Ejecución de la Cadena de Ataque por Componentes Técnicos

2.1 Capa 1 (Física) y Capa 2 (Enlace): WiFi Pumpkin 3 & Hostapd-mana

El objetivo de esta fase inicial es establecer el control perimetral mediante el despliegue de una infraestructura inalámbrica fraudulenta (Rogue AP) que fuerce la asociación de las víctimas, colocándolas automáticamente en un escenario Man-in-the-Middle (MITM) en la capa de enlace sin requerir ataques ruidosos como ARP Spoofing.

Justificación de las Herramientas:

WiFi Pumpkin 3 y Hostapd-mana son frameworks open-source líderes en la emulación de entornos inalámbricos maliciosos. Permiten levantar un AP falso interceptando las tramas de los clientes y gestionando los servicios críticos de red locales necesarios para el enrutamiento.

Despliegue Táctico y Configuración Clave:

Para simular el entorno y activar la suplantación de la red corporativa (SSID) utilizando WiFi Pumpkin 3, se configuran las directivas esenciales en su consola interactiva:

```
wp3 > set interface wlan0
wp3 > set ssid "WiFi_Corporativo_Legitimo"
wp3 > set proxy noproxy
wp3 > start
```

Paralelamente, Hostapd-mana complementa el ataque emitiendo respuestas maliciosas a las solicitudes de sondas de los clientes (Probe Responses), clonando las redes guardadas en sus Listas de Redes Preferidas (PNL).

Resultado e Impacto en el Flujo:

La ejecución exitosa consolida una pasarela de red controlada por el auditor. Los clientes se asocian al Rogue AP debido al nivel de señal superior. Al actuar la interfaz de red del atacante como puente físico, se obtiene visibilidad directa de todas las tramas Ethernet entrantes y salientes de la víctima, abriendo la puerta a los ataques de resolución de nombres.

2.2 Capa 3 (Red): DNS Poisoning mediante DNSChef

Establecido el control lógico de las tramas, el análisis asciende a la capa de red para manipular el flujo de las conexiones web de la víctima mediante la alteración de los registros de nombres de dominio.

Justificación de la Herramienta:

DNSChef es una aplicación gratuita escrita en Python concebida como un proxy DNS altamente configurable para analistas de malware y pentesters. Permite interceptar peticiones hacia servidores legítimos y suplantar las direcciones IP de destino de forma selectiva.

Despliegue Táctico y Configuración Clave:

Dado que el Rogue AP de la fase anterior ha asignado la IP del atacante como servidor DNS predeterminado a la víctima mediante DHCP, se levanta el servicio DNSChef para redirigir el tráfico del portal de autenticación corporativo a un servidor controlado:

```
python3 dnscchef.py --fakeip 192.168.1.105 --fakedomains login.megacorp.com --  
interface 0.0.0.0
```

Resultado e Impacto en el Flujo:

Cuando la víctima intenta resolver la dirección del portal corporativo, DNSChef intercepta la consulta y devuelve la dirección IP falsa (192.168.1.105). El navegador de la víctima inicia

la conexión contra el entorno del atacante, posibilitando la captura de flujos de autenticación e identidad de sesión superiores.

2.3 Capa 4 (Transporte): Evasión perimetral y Canales Encubiertos vía QUIC con Mitmproxy

Para garantizar la persistencia de las redirecciones y evitar que las sondas de inspección profunda de paquetes (DPI) del cortafuegos corporativo disparen alarmas, se requiere camuflar el tráfico a nivel de transporte.

Justificación de la Herramienta:

Mitmproxy es una suite open-source que implementa capacidades avanzadas de proxy de interceptación interactiva, contando con soporte nativo de inspección y decapsulación para el protocolo HTTP/3 y flujos cifrados basados en QUIC (UDP 443).

Despliegue Táctico y Configuración Clave:

Se inicializa el proxy intermedio configurado explícitamente para negociar y procesar flujos de transporte HTTP/3 y QUIC, evaluando si el perímetro intercepta este estándar de transmisión cifrada:

```
mitmproxy --mode regular --set connection_strategy=eager --set http3=true
```

Resultado e Impacto en el Flujo:

El uso de QUIC (UDP) impide que los cortafuegos perimetrales tradicionales que monitorizan flujos TCP analicen la sesión. Al encapsular la comunicación en un canal legítimo HTTP/3, se establece un canal encubierto y persistente de comunicación hacia la infraestructura externa sin levantar sospechas en los sistemas de monitorización tradicionales.

2.4 Capa 5 (Sesión): Pass-the-Ticket sobre Kerberos mediante Rubeus

Con la conexión segura establecida, el atacante busca consolidar privilegios en la capa de sesión mediante la manipulación de identidades del dominio en sistemas Windows Active Directory.

Justificación de la Herramienta:

Rubeus es una herramienta gratuita y de código abierto escrita en C# diseñada específicamente para interactuar de forma avanzada con el protocolo de autenticación Kerberos desde una perspectiva ofensiva y defensiva.

Despliegue Táctico y Configuración Clave:

Aprovechando el acceso local o la captura previa de un ticket de otorgamiento de tickets (TGT) válido de la víctima, se ejecuta Rubeus para inyectar dicho artefacto directamente en la memoria del subsistema de seguridad (LSASS) de la sesión actual sin requerir contraseñas en texto claro:

```
Rubeus.exe ptt /ticket:doIE1jCCBNagAwIBBaEDAgEWooIEXTCCBFhggRVMIIDUaADAg...
```

Resultado e Impacto en el Flujo:

La inyección del ticket Kerberos burla el mecanismo de sesión estándar. La máquina del atacante asume la identidad del usuario afectado de forma legítima ante los controladores del dominio, facilitando movimientos laterales directos hacia las aplicaciones corporativas web que dependen de la confianza del dominio.

2.5 Capa 6 (Presentación): Falsificación de Tokens mediante Burp Suite (Comunidad / JWT Editor)

Al interactuar con las aplicaciones web modernas del objetivo, el control de la identidad lógica se traslada a las estructuras de datos interpretadas por el backend, analizando fallos en el formateo de tokens JWT.

Justificación de la Herramienta:

Burp Suite Community Edition es el proxy de interceptación web gratuito de referencia en la industria. Combinado con la extensión open-source 'JWT Editor', proporciona capacidades completas para analizar, parsear y firmar estructuras de datos JSON Web Tokens.

Despliegue Táctico y Configuración Clave:

El auditor intercepta la petición HTTP de la aplicación y detecta la cabecera 'Authorization: Bearer <token>'. Utilizando la pestaña de JWT Editor, modifica el encabezado para forzar la aceptación de tokens sin validar desactivando el algoritmo de firma (ataque del algoritmo `none`), alterando en el payload el parámetro del usuario al rol de administrador:

Modificación del Encabezado HTTP Interceptado:

Antes: { "alg": "RS256", "typ": "JWT" }

Después: { "alg": "none", "typ": "JWT" }

Payload Modificado: { "user": "admin", "role": "superuser" }

Resultado e Impacto en el Flujo:

Si la biblioteca de la capa de presentación del backend adolece de validaciones rigurosas, el servidor interpreta el token manipulado como una identidad legítima con altos privilegios, permitiendo saltarse la autenticación tradicional y acceder a funciones protegidas.

2.6 Capa 7 (Aplicación): Exfiltración con IDOR y Exposición CORS usando OWASP ZAP

El vector concluye en la capa superior donde se materializa el acceso inapropiado a las funciones del negocio y los datos confidenciales de la organización.

Justificación de la Herramienta:

OWASP ZAP (Zed Attack Proxy) es una de las herramientas de código abierto y completamente gratuita más activas del mundo para auditorías de seguridad en aplicaciones web y APIs, ideal para el descubrimiento de fallos de lógica y directivas de control de acceso cruzado.

Despliegue Táctico y Configuración Clave:

Utilizando las credenciales y tokens alterados, el auditor emplea el módulo 'Fuzzer' de OWASP ZAP para realizar solicitudes HTTP iterativas sobre los parámetros lógicos de una API propensa a IDOR, manipulando variables secuenciales numéricas:

Petición Fuzzed en OWASP ZAP:

GET /api/v1/usuarios/perfil?id=[Payload_Secuencial_Del_Fuzzer] HTTP/1.1

Host: api.megacorp.com

Authorization: Bearer <token_none>

De forma simultánea, se comprueba si el servidor devuelve la cabecera permisiva `Access-Control-Allow-Origin: \*` junto con credenciales, validando un fallo crítico en las directivas CORS.

Resultado e Impacto en el Flujo:

La combinación del IDOR permite listar masivamente los perfiles de todos los clientes de la base de datos sin restricciones de propiedad, mientras que la debilidad de CORS demuestra que un atacante puede exfiltrar estos datos de manera automatizada mediante scripts cargados externamente desde el navegador del usuario afectado, completando el ciclo completo de la cadena de compromiso.